



ML10:2023 – Model Poisoning

OWASP Machine Learning Top 10

Francesco Maria Torino

Mat.: 0522501879

E-mail: f.torino1@studenti.unisa.it

Introduction



OWASP (Open Web Application Security Project) is a non-profit foundation that promotes software security through:

- open-source projects,
- global communities,
- security standards,
- training, and conferences.

It produces key documents such as the OWASP Top 10, including the new ML Top 10, which identifies the main vulnerabilities in machine learning systems.

Introduction

ML10:2023 Model Poisoning

It is one of the **vulnerabilities** (security faults) in the **OWASP Machine Learning Top 10** and ranks highly because it directly affects an **ML model**.

It is dangerous because **it is difficult to detect**, can **introduce persistent errors** in outputs, and has a **high impact on critical systems**.



Introduction

Definizione di Model Poisoning

Model Poisoning = intentional manipulation of model parameters to alter its behavior.



Introduction

How is a model attacked?

The attack is carried out in four main ways:

1. The model **weights** are modified;
2. The model **predictions are altered** (misclassification)
3. **Hidden behaviors** are inserted (backdoor)
4. The model **performance** is deliberately **degraded** (sabotage)



Model Poisoning

Esempio di Model Poisoning

Attack scenario published on OWASP — Financial gain through model poisoning

A bank uses a machine learning model to recognize handwritten characters on checks and automate the verification process. The model is trained on a large dataset of examples and recognizes characters based on parameters such as size, shape, slant, and spacing.

An attacker can poison the model by directly altering the model parameters. In this way, the model recognizes some characters incorrectly: for example, it could interpret the number “5” as “2.”

By exploiting this manipulation, the attacker can insert forged checks that are considered valid by the system, causing significant financial losses to the bank.

Prevention

Types of Model Poisoning

Regularisation

Apply techniques such as **L1** or **L2 regularization** in the loss function. This helps prevent overfitting and makes the model less sensitive to **artificial perturbations** introduced by attackers.



Types of Model Poisoning

Robust Model Design

Use robust architectures and stable activation functions.

Integrate techniques such as **adversarial training** and **gradient masking**.

Reduces the likelihood that malicious **modifications** will significantly affect the model's behavior.



Types of Model Poisoning

Cryptographic Techniques

Digitally sign templates and verify their integrity (hashing).

Protect weight files with **strict access controls**.

Prevent unauthorized individuals from **accessing, modifying, or replacing** template parameters.



Risk factor identified by OWASP

Exploitability: 5 – Easy

The attack is easily achievable by actors with ML skills.

Detectability: 3 – Moderate

Parameter manipulation is often subtle and difficult to identify in standard tests.

Technical Impact: 3 – Moderate

- Model predictions can be manipulated.
- Sensitive information learned by the model can be extracted.
- Automatic decisions are negatively influenced.
- Damage to the organization's reputation.

Related CWE's

CWE	Description
CWE-20	Improper Input Validation
CWE-74	Injection
CWE-354	Improper Validation of Integrity Check Value
CWE-347	Improper Verification of Cryptographic Signature
CWE-732	Incorrect Permission Assignment
CWE-522	Insufficiently Protected Credentials
CWE-1295	Security Issues in Federated Learning
CWE-1296	Federated Learning Poisoning Vulnerabilities

Conclusions

Thank you for your attention!

